

PROJECT REPORT: CYBERSECURITY RISK ASSESSMENT FRAMEWORK FOR SMEs

Project Title: Cybersecurity Risk Assessment Framework for Small and Medium Enterprises (SMEs)

Project Category: Minor Project 1

Author: Aditya Sonune

ABSTRACT

This project addresses the critical need for accessible cybersecurity risk management within Small and Medium Enterprises (SMEs). Given the limited IT budgets and technical resources typical of this sector, SMEs are frequently targeted by automated and opportunistic cyber-attacks. This report details the development of a simplified risk assessment model derived from the NIST Cybersecurity Framework. The model is supported by a Python-based automated risk calculator and an interactive web dashboard, enabling non-technical stakeholders to identify, score, and mitigate digital threats effectively.

TABLE OF CONTENTS

1. [Introduction](#)
 2. [Problem Statement](#)
 3. [Objectives](#)
 4. [Methodology](#)
 5. [Implementation \(Technical Tools\)](#)
 6. [Results & Case Studies](#)
 7. [Proposed Mitigation Strategies](#)
 8. [Conclusion](#)
-

1. INTRODUCTION

Cybersecurity has transitioned from a supporting IT function to a fundamental business requirement. SMEs, while often overlooked in the media compared to large corporations, form the backbone of the global supply chain. This project provides a practical "first line of defense" framework that empowers small business owners to manage their security posture without requiring enterprise-level investments.

2. PROBLEM STATEMENT

A significant majority of SMEs operate under a "security through obscurity" fallacy, assuming they are too small to attract malicious attention. However, modern threats like ransomware and phishing are largely automated and target vulnerabilities, not specific company names. The primary barriers for SMEs are:

- **Complexity:** Existing global standards (NIST, ISO) are too resource-heavy for small teams.
- **Cost:** Professional security consulting is often prohibitively expensive.
- **Awareness:** Lack of a standardized way to quantify risk leads to reactive rather than proactive security spending.

3. OBJECTIVES

The core objectives of this minor project include:

1. **Framework Simplification:** Adapting global standards into a manageable 1-to-25 risk scoring system.
2. **Automation:** Developing a reproducible Python tool for consistent risk reporting.
3. **Visualization:** Creating a web-based dashboard to bridge the gap between technical risk and business decision-making.
4. **Strategic Recommendations:** Identifying high-impact, low-cost security controls.

4. METHODOLOGY

The project utilizes the **NIST Cybersecurity Framework (CSF)** as its foundation, focusing on the five core functions: Identify, Protect, Detect, Respond, and Recover.

4.1 The Risk Calculation Model

Risks are quantified using a 5×5 matrix where:

$$\text{Risk Score} = \text{Likelihood (1-5)} \times \text{Impact (1-5)}$$

Scoring Matrix Overview:

- **1 - 6 (Low Risk):** Acceptable risk; maintain current controls.
- **8 - 12 (Moderate Risk):** Action required; plan mitigation within 90 days.
- **15 - 25 (High Risk):** Urgent; implement immediate controls to prevent business failure.

5. IMPLEMENTATION (TECHNICAL TOOLS)

5.1 Python Risk Calculator (`risk_calculator.py`)

A command-line tool written in Python to ensure objective risk scoring.

- **Features:** User-friendly prompts, instant risk level categorization, and CSV data export for compliance record-keeping.

5.2 Interactive Web Dashboard (`index.html`)

A front-end dashboard built with HTML5, CSS3, and JavaScript.

- **Features:** Real-time risk visualization, glassmorphism design for modern aesthetics, and responsive layout for mobile/tablet accessibility.

6. RESULTS & CASE STUDIES

The model was validated against two primary threat vectors:

1. **Phishing (Credential Theft):** Analysis proved that while the likelihood is "Likely" (4), the implementation of MFA reduces the impact from "Critical" (5) to "Minor" (2), effectively shifting the risk from High to Low.
2. **Supply Chain Ransomware:** Demonstrated that the "Recover" phase (3-2-1 backups) is the only definitive way to mitigate a "Critical" impact event when prevention fails.

7. PROPOSED MITIGATION STRATEGIES

I recommend the following prioritized security roadmap for SMEs:

- **Identity Management:** Enforce Multi-Factor Authentication (MFA) across all cloud and local services.
- **Data Resiliency:** Implement the 3-2-1 backup rule (3 copies, 2 media, 1 offsite).
- **Cycle Management:** Activate automated patching for all operating systems and software.
- **Human Firewall:** Conduct quarterly security awareness training for all staff.

8. CONCLUSION

Cybersecurity is not an "all-or-nothing" game. Small businesses can achieve significant resilience by focusing on high-impact basics. This project shows that through structured risk assessment and simple automation tools, SMEs can effectively bridge the security gap and protect their long-term business continuity.